

Manual 08 - Vendor and Third-Party Risk Lifecycle

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: c065e9ba7b7bbf37ff7c05de081a5864879e12ef | Language: en | supplier-risk and human decision boundaries retained.

Assurance boundary: Risk-based supplier governance reduces uncertainty but does not eliminate third-party or fourth-party risk. Evidence can be incomplete, stale, externally controlled, or subject to material change. Accountable human owners retain approval, exception, residual-risk, renewal, and exit decisions.

Implementation paths

Manual 08 — Vendor and Third-Party Risk Lifecycle Implementation Paths

Essential

Use for smaller organizations or bounded supplier ecosystems. Minimum expectations:

- complete vendor/service inventory and accountable owner;
- criticality/inherent-risk classification;
- evidence-based due diligence proportionate to risk;
- documented approve/condition/reject decision;
- required contract/security/privacy clauses;
- onboarding access/data controls;
- incident/change notification route;
- periodic evidence refresh and reassessment;
- offboarding, access revocation, data return/deletion evidence.

Structured

Use for multiple critical suppliers, regulated data, cloud/SaaS reliance, material outsourcing, or AI/model/API providers. Add:

- standardized tiering methodology;
- control/evidence requirements by tier;
- fourth-party/subprocessor visibility;
- independent evidence validation and exception tracking;
- resilience/BCDR and concentration-risk review;
- continuous monitoring signals and trigger-based reassessment;
- formal remediation plans and risk acceptance;
- renewal gates tied to unresolved issues.

Enhanced

Use for critical infrastructure, enterprise-scale outsourcing, high-impact AI, systemic cloud dependencies, regulated/high-volume data, or concentrated supplier risk. Add:

- executive risk governance and concentration scenarios;
- architecture/data-flow/component lineage;
- deeper technical testing or independent assurance where justified;
- material fourth-party dependency analysis;
- contractual audit/access/incident/exit protections;
- joint incident and resilience exercises;
- contingency/exit strategy validation;

- continuous evidence and material-change monitoring.

Lifecycle route

Manual 08 memory graphic 1

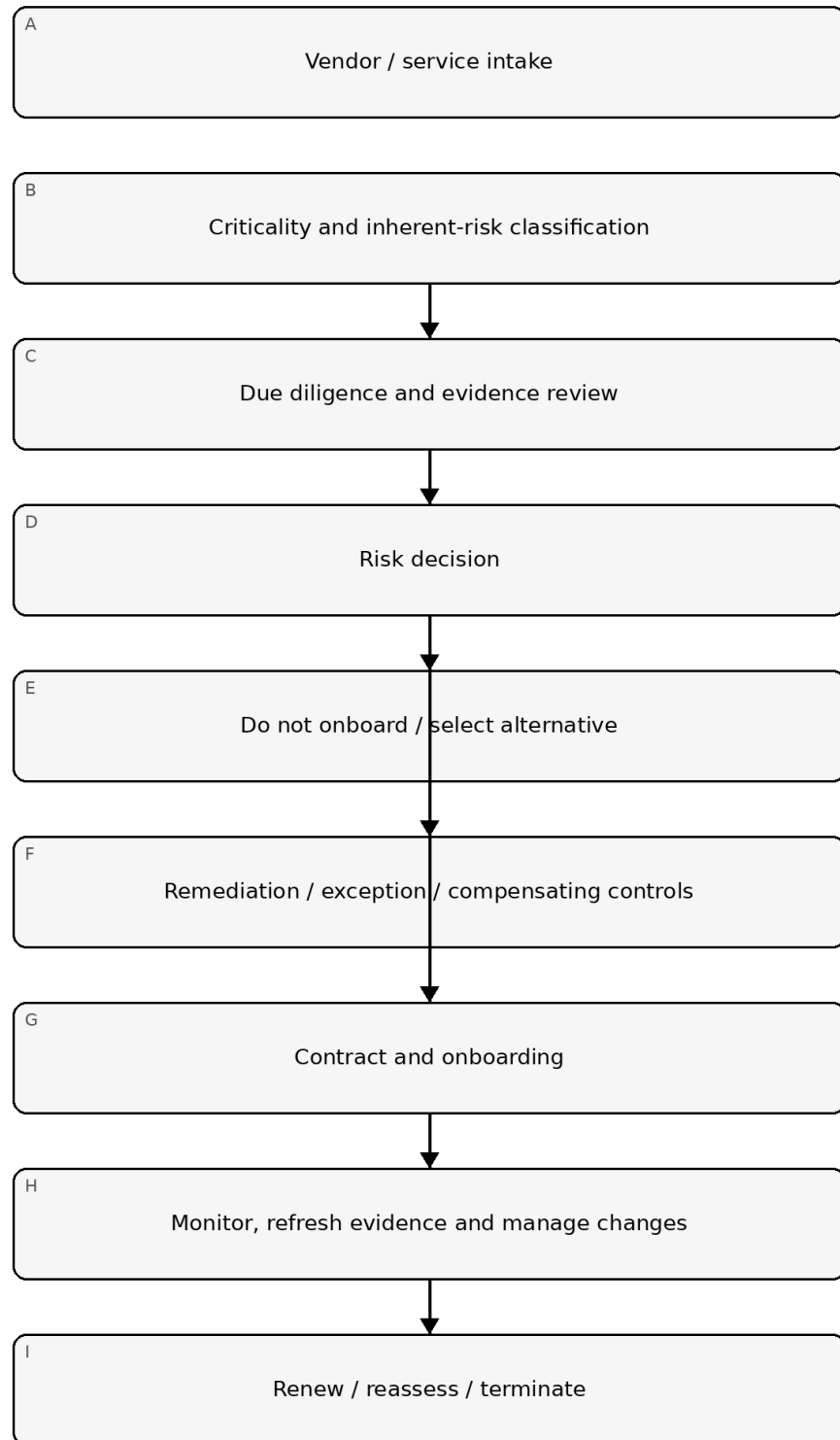


Figure 1. Implementation memory graphic

Accessible explanation: Every supplier begins with classification and due diligence. Decisions may reject, conditionally approve, or approve the relationship. Approved suppliers move into monitored operation and are reassessed at renewal, material change, or termination.

Evidence and decision chain

Manual 08 memory graphic 2

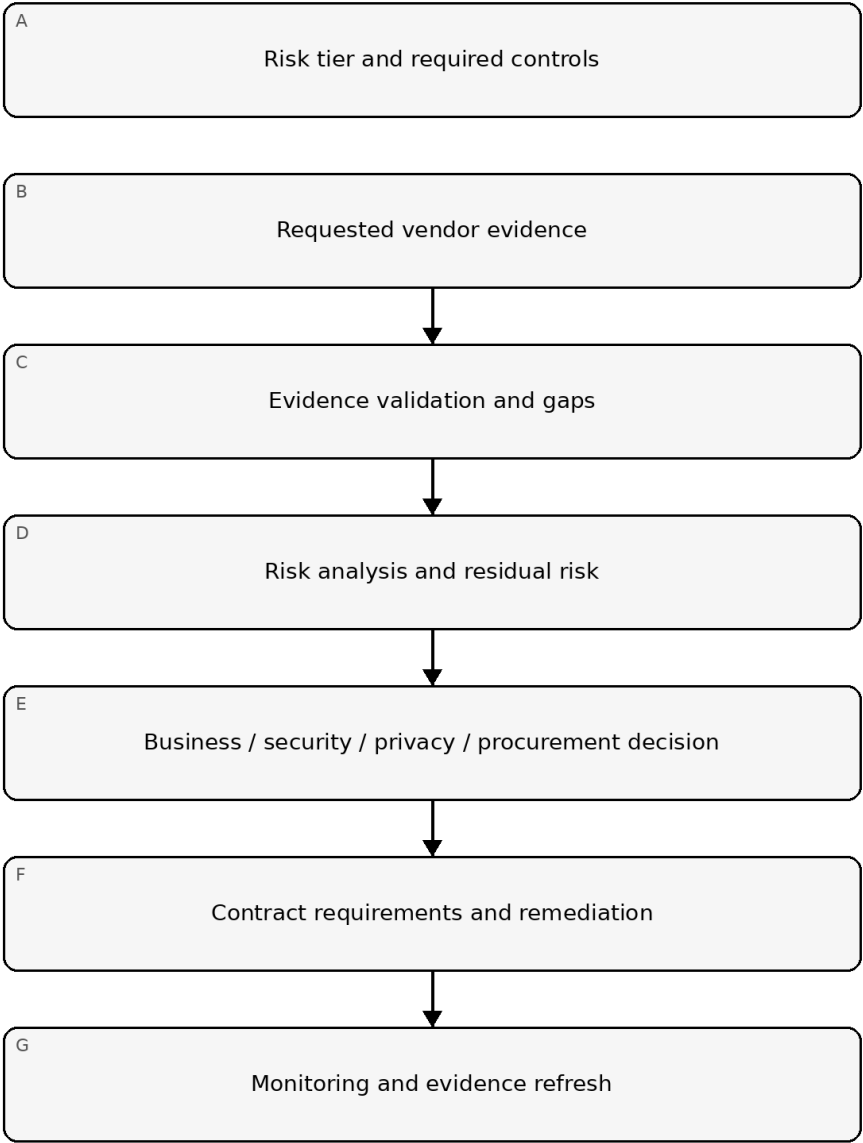


Figure 2. Implementation memory graphic

Accessible explanation: Vendor decisions are based on required controls, verified evidence, identified gaps, and residual risk. The resulting decision drives contracts, remediation, and ongoing monitoring rather than ending at questionnaire completion.

Fourth-party and AI dependency chain

Manual 08 memory graphic 3

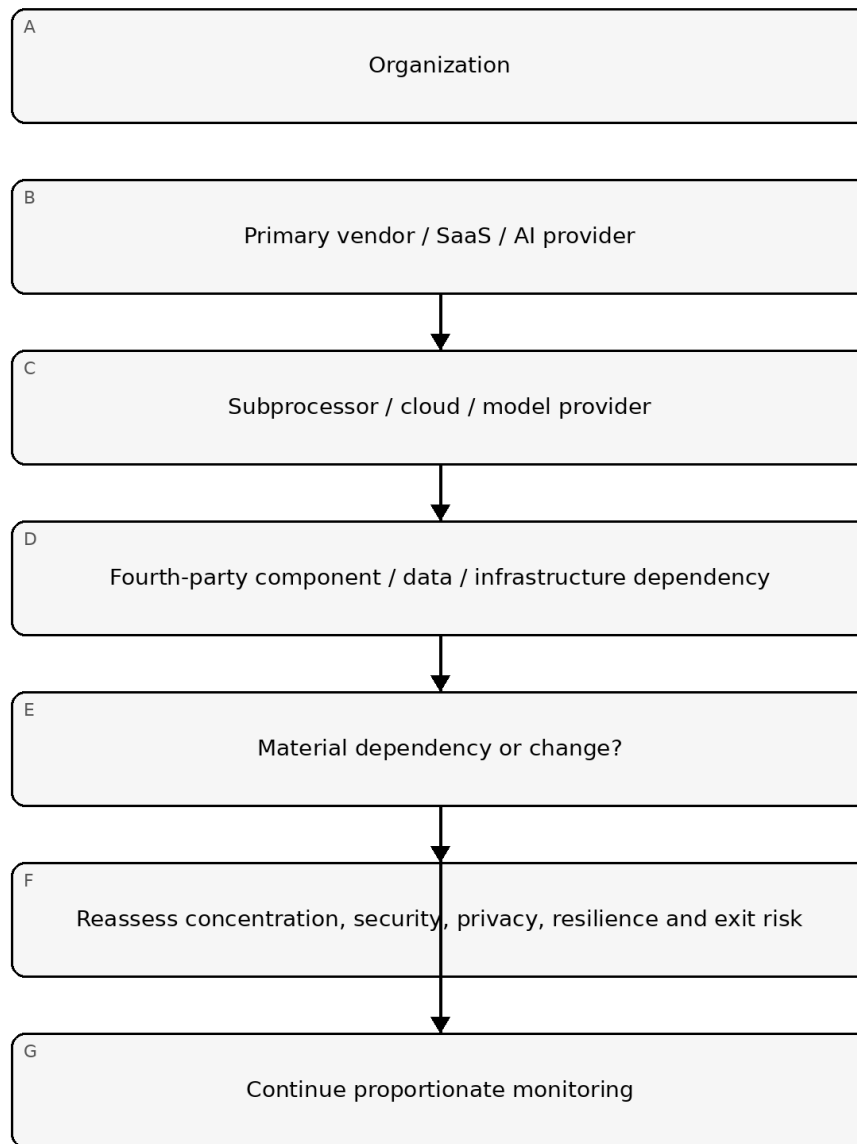


Figure 3. Implementation memory graphic

Accessible explanation: Supplier risk can extend beyond the contracted vendor to subprocessors, cloud/model providers, and fourth-party dependencies. Material dependencies and changes trigger reassessment rather than being hidden behind the primary contract.

Required lifecycle controls

1. Vendor/service inventory and ownership.
2. Criticality, inherent-risk, data, access, geography, regulatory and concentration classification.
3. Security, privacy, resilience, AI, financial/operational and compliance due diligence as applicable.
4. Evidence validation—including certifications, reports, architecture, policies, test evidence, incidents and remediation—not questionnaire-only assurance.
5. Risk decision and documented exception/risk acceptance.

6. Contract controls: data use, confidentiality, security, incident notice, audit/evidence rights, subprocessors, resilience, AI use, retention, deletion and exit.
7. Onboarding identities, connectivity, data flows, keys/secrets and ownership.
8. Continuous monitoring, evidence refresh and material-change triggers.
9. Incident, breach, service disruption, control failure and remediation management.
10. Renewal and reassessment gates.
11. Offboarding: access revocation, asset/key return, data return/deletion, retention and transition/exit evidence.

Assurance boundary

Risk-based supplier governance reduces uncertainty but cannot eliminate third-party risk. The manual must preserve known gaps, reliance on external evidence, fourth-party limitations, residual risk, and accountable human decisions.

Controlled 32-chapter manual

Chapter 01 — TPRM objective and lifecycle

Third-party risk management should govern the full relationship lifecycle: intake, classification, due diligence, risk decision, contracting, onboarding, monitoring, issue/change management, reassessment, and offboarding.

The process should apply proportionally based on what the supplier can access, influence, process, host, operate, or disrupt.

Chapter 02 — Vendor inventory and ownership

Maintain a controlled inventory of suppliers, service providers, subprocessors, AI/model providers, data providers, APIs, hosting services, and other material external dependencies.

Each record should identify the business owner, service, data handled, system dependencies, contract, criticality, geography where relevant, fourth-party exposure, renewal date, monitoring tier, and exit requirements.

Chapter 03 — Criticality and inherent risk

Criticality asks what happens if the supplier fails; inherent risk asks what exposure exists before considering controls. These are related but not identical.

Factors may include sensitive-data access, privileged connectivity, production access, operational dependency, concentration, substitutability, financial impact, regulatory exposure, AI autonomy, model or data dependency, and business-continuity consequences.

Chapter 04 — Due diligence planning

Due diligence should be evidence-based and proportional. The review plan should identify the questions to answer, evidence needed, reviewers, and acceptance thresholds.

Potential evidence includes policies, independent reports, certifications, architecture information, test results, incident history, resilience evidence, privacy documentation, contractual commitments, financial information, and targeted interviews.

A questionnaire alone is not assurance for a material supplier.

Chapter 05 — Security, privacy, and resilience review

Review should determine whether supplier controls are appropriate to the service and exposure. Security, privacy, and resilience should be assessed as connected disciplines rather than isolated questionnaires.

The review should address identity, access, data protection, logging, vulnerability management, incident response, recovery capability, subcontracting, location, retention, deletion, and service continuity where applicable.

Chapter 06 — AI suppliers and model/component dependencies

AI supplier review should identify model providers, hosted inference, fine-tuning services, data suppliers, safety services, retrieval sources, agent/tool providers, and other AI components.

Key questions include data use, training or retention behavior, model/version change notification, security boundaries, content and abuse controls, service availability, intellectual-property terms, audit evidence, incident notification, and exit options.

Chapter 07 — Risk decision and exceptions

Every material due-diligence outcome should produce a decision: approve, conditionally approve, require remediation, restrict scope, defer, or reject.

Exceptions should record the unmet requirement, business justification, compensating control, owner, residual risk, approver, expiration date, and monitoring requirement. Permanent exceptions without periodic review should be avoided.

Chapter 08 — Fail-closed onboarding gate

Onboarding should fail closed when required due diligence is incomplete, critical evidence is missing, high-risk findings lack approved treatment, required contract terms are unresolved, or mandatory human approval is absent.

A supplier may not be represented as “approved” merely because procurement is complete. Material change after approval—such as a new subprocessor, service model, data use, AI component, hosting location, or security architecture—can reopen the affected review gate.

Chapter 09 — Evidence quality

Evidence should be evaluated for relevance, currency, scope, independence, and applicability to the actual service. A document can be valid yet still irrelevant if it covers a different product, environment, entity, or period.

Chapter 10 — Contract control requirements

Material risks identified during due diligence should be reflected in contract terms where appropriate. Topics may include security obligations, privacy/data handling, audit rights, incident notification, subcontracting, service levels, resilience, change notification, data return/deletion, and exit support.

Chapter 11 — Right to audit and assurance access

Right-to-audit language should be usable in practice. The organization should understand whether assurance will be provided through reports, certifications, evidence packages, interviews, targeted reviews, onsite work, or other mechanisms.

Chapter 12 — Subprocessors and fourth parties

Material subprocessors and fourth parties should be visible enough to understand concentration, data handling, operational dependency, and change risk. The level of visibility should be proportional to exposure and criticality.

Chapter 13 — Concentration and dependency risk

Risk assessment should consider whether multiple critical processes rely on one supplier, region, platform, model provider, cloud service, or upstream dependency. Concentration may be hidden when different vendors share the same underlying service.

Chapter 14 — Resilience and recovery evidence

For critical services, due diligence should examine recovery capability, dependency assumptions, test evidence, recovery objectives, communication processes, and whether the organization has a viable fallback or exit path.

Chapter 15 — Incident notification and coordination

Contracts and operating procedures should establish how material supplier incidents are reported, what information is expected, who receives notification, and how joint containment, investigation, recovery, and regulatory or customer communications are coordinated.

Chapter 16 — Approval package

The approval package should summarize service scope, criticality, inherent risk, due-diligence evidence, material findings, contractual treatments, open exceptions, residual risk, monitoring tier, exit considerations, and human approval. Approval must correspond to the actual service and scope reviewed.

Chapter 17 — Onboarding controls

Onboarding should verify that approved contract terms, access boundaries, data-handling requirements, security contacts, incident contacts, monitoring tier, and service ownership are implemented before production use.

Chapter 18 — Continuous monitoring

Monitoring should focus on indicators linked to material risk: security events, service degradation, financial distress, ownership changes, compliance changes, subcontractor changes, model or platform changes, unresolved findings, and contract obligations.

Chapter 19 — Evidence refresh

Evidence should be refreshed according to risk and expiration. Independent reports, certifications, policies, test evidence, insurance, privacy documents, and resilience artifacts should not remain credited indefinitely after they become stale.

Chapter 20 — Change management

Material vendor changes should trigger impact analysis. Examples include new subprocessors, new hosting regions, architecture changes, changes in data use, mergers, service-model changes, AI/model changes, or changes to security or privacy commitments.

Chapter 21 — Issue and remediation governance

Findings should have owners, severity, actions, dates, evidence, and escalation. Repeated missed remediation dates should affect risk treatment and may require service restrictions, additional controls, executive acceptance, or exit planning.

Chapter 22 — Exception management

Exceptions should be time-bound and approved by appropriate authority. Monitoring should verify that compensating controls remain effective and that expiration dates are not bypassed through administrative renewal without reassessment.

Chapter 23 — Periodic reassessment

Reassessment should consider current service scope, criticality, data use, control evidence, incidents, supplier changes, performance, concentration, fourth-party exposure, contract status, and exit readiness.

Chapter 24 — Renewal decision

Renewal should be a risk decision, not an automatic procurement event. The approval record should identify unresolved findings, changed exposure, current evidence, residual risk, and whether contract terms or monitoring need to change.

Chapter 25 — Performance and service-risk review

Operational performance should be evaluated alongside control evidence. Persistent service failures, missed commitments, support degradation, or repeated incidents can change residual risk even when formal assurance documents remain current.

Chapter 26 — Financial and strategic dependency

Where material to service continuity, the organization should consider financial viability, ownership changes, acquisition risk, strategic dependency, and the feasibility of replacing the supplier.

These considerations should be handled proportionately and with appropriate specialist input.

Chapter 27 — Data return and deletion

Exit planning should define what data, configurations, logs, artifacts, models, prompts, or other information must be returned, transferred, retained, or deleted. Completion should be evidenced where contractual or regulatory requirements apply.

Chapter 28 — Access termination

Offboarding should revoke accounts, credentials, API keys, network access, privileged access, support access, integrations, certificates, and other supplier connectivity that is no longer required.

Chapter 29 — Transition and continuity

Critical suppliers should have a realistic transition plan that considers replacement services, data migration, technical dependencies, knowledge transfer, timing, and interim controls.

An exit plan that cannot be executed within business tolerances should be treated as a current risk.

Chapter 30 — Residual obligations

After service termination, some obligations may survive, including confidentiality, record retention, data deletion, incident cooperation, audit support, intellectual-property terms, or legal holds. These should be tracked until complete.

Chapter 31 — TPRM assurance limitations

A controlled TPRM process reduces uncertainty but cannot certify a supplier as risk-free. Conclusions should identify the evidence, scope, time period, assumptions, and limitations on which they depend.

Chapter 32 — Manual release boundary

Before this manual is published, source verification, the complete controlled English master, multidisciplinary review, es-419 and pt-BR semantic review, graphics/accessibility review, document and page QA, provenance, repository/security release audit, and Final Human Release Approval must be complete.

Material content changes after human approval reopen the affected gates.